



King Fahd University of Petroleum & Minerals

College of Computing and Mathematics

Information and Computer Science Department

ICS 344: Information Security (Term 242)

Course Project

Group: 06

Sec: 01

TABLE OF CONTENTS

INTRODUCTION	4
1. PHASE 1: SERVICE SETUP AND COMPROMISE	4
1.1 Victim Machine Setup (Metasploitable3)	5
1.2 Attacker Machine Setup (Kali Linux).....	6
1.3 Service Selected for Attack.....	6
1.4 Vulnerability Discovery	7
1.4.1 Nmap Scan	7
1.4.2 Nikto Scan.....	8
1.5 Attack Execution (Metasploit Attempt).....	8
1.6 Custom Script Attack (Python Script).....	9
2 PHASE 2: SIEM (SPLUNK) ATTACK LOG ANALYSIS AND VISUALIZATION.....	11
2.1 Splunk Setup and Installation	11
2.1.1 Installation Steps.....	12
2.2 Attack Data Collection.....	14
2.2.1 Nmap Scan	14
2.2.2 Nikto Web Server Vulnerability Scan	14
2.2.3 Custom Python Script for HTTP Banner Grabbing	15
2.3 Data Ingestion into Splunk.....	15
2.4 Searching Attack Events	16

2.5	Dashboard Creation and Visualization.....	17
3	PHASE 3: DEFENSIVE STRATEGY PROPOSAL AND IMPLEMENTATION	20
3.1	Defense Strategy Selected.....	20
3.2	Defense Implementation	21
3.2.1	Securing IIS Configuration	21
3.2.2	Applying Firewall Rules	23
3.3	Retesting the Attack	24
3.4	Before-and-After Comparison	25
3.5	Analysis.....	26
4	CONCLUSION.....	27
5	REFERENCES	27

INTRODUCTION

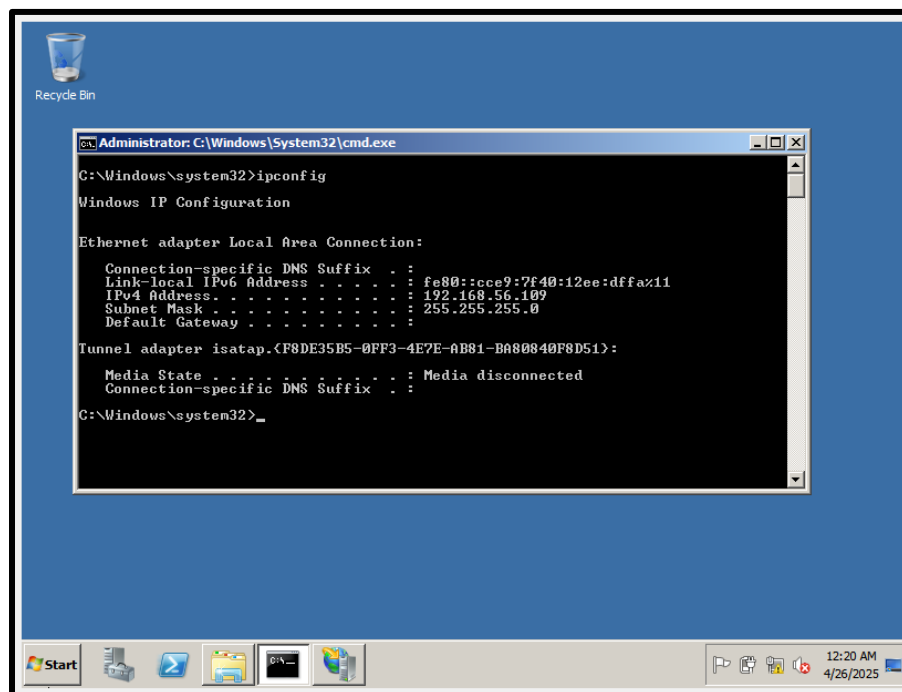
With the development in technology, a threat that did not exist before is omnipresent now. Cyberattacks are a danger not only for governments but also for homes and business facilities. Details of confidential infrastructure are accessible to unauthorized attackers who take advantage of crevices that provide them loopholes. Simulating realistic scenarios helps improve cyber defense mechanisms. In this case, the metasploitable3 service was deployed which served as a vulnerable target machine. The attacker possessed a machine that ran with Kali Linux which is backed with penetration testing tools. The outlined project steps included target system's vulnerability discovery, applying exploit strategies, monitoring attacks using SIEM systems, reclaiming control of affected services, and executing countermeasures to defeat offensive cyber maneuvers. SIEM tools enable effective attack log retrieval and incident analysis where Splunk serves as a predominant tool. Further exploitation where the target is prone before system hardening is implemented, can be prevented through firewall policies and system strengthening. The security cycle of exploits and attacks alongside the defensive strategies taken is recorded. This project can be divided into three basic phases: 1) Compromise of the Service, 2) Preattack graphical information system visualization, and 3) Implementation of strategy for defense.

1. PHASE 1: SERVICE SETUP AND COMPROMISE

This phase involved the configuration of the attacker and victim machines that provided a weak security posture. The goal was to find and exploit a service on the target machine using standard penetration testing methodologies and tools. I have detailed every step throughout the entire process from setting up the environment to compromising the target service accompanied by screenshots documenting corresponding key milestones.

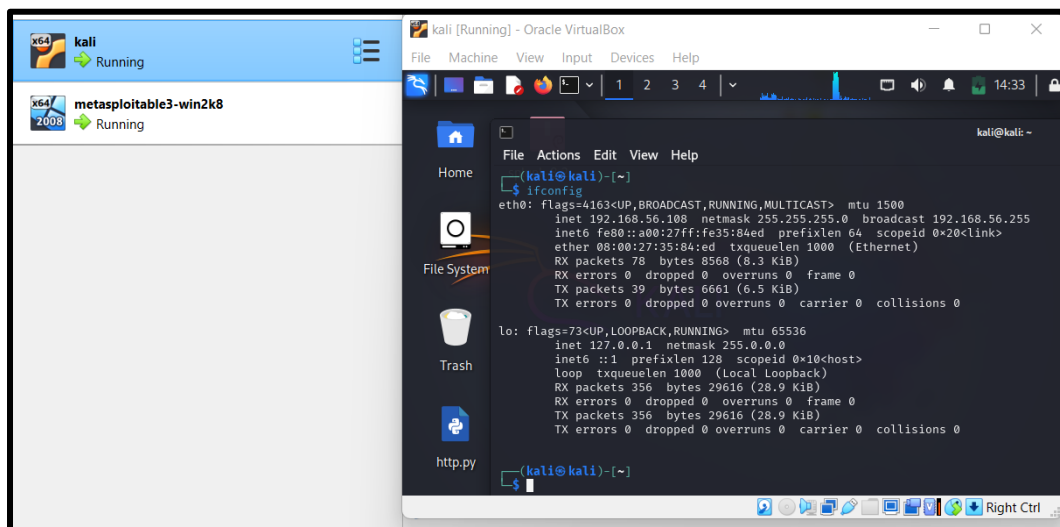
1.1 Victim Machine Setup (Metasploitable3)

In order to emulate the real-world vulnerable environment scenario, for this particular project, the victim machine was set to Windows Server 2008 R2 Metasploitable3. Metasploitable3 is renowned amongst Windows server users as it offers an intentionally vulnerable machine specially designed for exploitation, learning, and practice purposes. The entire process was done with the help of Vagrant and Virtual Box. Vagrant not only helped automate the building and provisioning of the vulnerable environment, but also offered the hypervisor virtual box which is used for running the virtual machines. This process requires cloning the Metasploitable3 repository, installing required dependencies such as packer and other required vagrant plugins and finally executing the build scripts in order to create the virtual machine for Windows Server 2008 R2. After completing all the aforementioned steps, the virtual machine was seamlessly running on virtual box. In order to perform proper scanning and exploitation, the machine was set to work on the same network as the attacker machine.



1.2 Attacker Machine Setup (Kali Linux)

For the purpose of conducting the attacks and vulnerability assessments, Kali Linux 2024 was chosen as the attacker virtual machine. This OS is a penetration testing distribution install because it comes with various inbuilt security tools like Nmap, Nikto, Metasploit Framework and Metasploitable which makes it a perfect candidate for testing in ethical hacking and cybersecurity labs. To ensure the VLAN configuration for the Kali Linux Virtual Machine to Operate with VirtualBox was suite over the internal network with the victim machine (Metasploitable3), it was installed and configured on VirtualBox. This configuration enabled full network communication as well as seamless execution of scanning, attacking and logging in automating processes. It also made certain that all the default installation repositories were updated to ensure the availability of current penetration testing tools ready for execution.



1.3 Service Selected for Attack

This project targeted services - and exploited - HTTP using Microsoft IIS 7.5. On most servers, HTTP services are among the most, if not the most, utilized serviced offered. In the past, attackers,

more often than not, target services due to rampant, or common, misconfigurations, utilized outdated software, or employed weak security controls. The victim machine was discovered to be running a webserver on port 80. It's service was detected using both Nmap and Nikto tools. Based on the Nmap service detection scan, it was identified as Microsoft-IIS/7.5, which has known unmitigated several vulnerabilities. In lieu of conditions, lacking in security and exposed at a perimeter such as a network, HTTP stood out as the most optimal service to attack and analyze in the project's scope.

1.4 Vulnerability Discovery

To examine a possible weakness in the victim machine, Nmap and Nikto spyware tools were employed.

1.4.1 Nmap Scan

An Nmap scan was controlled on the target machine (Metasploitable3) in order to determine available ports as well as services.

The following outcomes were achieved:

- Port 80 (HTTP) was enabled.
- Serviced hosting was Microsoft IIS httpd 7.5.
- This shows It's quite possible there is a weak web server.

```
(kali@kali)-[~/Desktop]
$ nmap -sV -p 80 192.168.56.109
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-26 04:46 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.109
Host is up (0.00056s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 7.5
MAC Address: 08:00:27:31:B6:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.13 seconds

(kali@kali)-[~/Desktop]
$
```

1.4.2 Nikto Scan

Moreover, a Nikto scan was conducted regarding the specific details of the HTTP service (port 80) to search for web-related vulnerabilities.

The results from Nikto indicated:

- Security headers X-Frame-Options and X-Content-Type-Options are absent.
- Default IIS pages are still present.
- The web server in question has been identified as Microsoft-IIS/7.5.
- Methods including OPTIONS, TRACE, GET, HEAD, POST were permitted.

Defaults set in these systems grant potential attackers serious issues to exploit.

```
(kali@kali)-[~/Desktop]
$ nikto -h http://192.168.56.109
- Nikto v2.5.0

+ Target IP: 192.168.56.109
+ Target Hostname: 192.168.56.109
+ Target Port: 80
+ Start Time: 2025-04-26 04:51:36 (GMT-4)

+ Server: Microsoft-IIS/7.5
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ /: Appears to be a default IIS 7 install.
+ 810 requests: 0 error(s) and 5 item(s) reported on remote host
+ End Time: 2025-04-26 04:52:04 (GMT-4) (28 seconds)

+ 1 host(s) tested

(kali@kali)-[~/Desktop]
$
```

1.5 Attack Execution (Metasploit Attempt)

After identifying the vulnerable HTTP service, an attempt was made to exploit it using the **Metasploit Framework**.

The following steps were performed:

- **Module Used:**

```
auxiliary/scanner/http/webdav_scanner
```

- **Configuration Commands:**

```
use auxiliary/scanner/http/webdav_scanner
```

```
set RHOSTS 192.168.56.109
```

```
run
```

The scan has indicated that Microsoft-IIS/7.5 was operational on the target machine, and it completed successfully. However, since WebDAV was found to be disabled, this attack pathway could not be advanced through WebDAV exploits.

```
msf6 > use auxiliary/scanner/http/webdav_scanner
msf6 auxiliary(scanner/http/webdav_scanner) > set RHOSTS 192.168.56.109
RHOSTS => 192.168.56.109
msf6 auxiliary(scanner/http/webdav_scanner) > run
[*] 192.168.56.109 (Microsoft-IIS/7.5) WebDAV disabled.
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/webdav_scanner) > █
```

1.6 Custom Script Attack (Python Script)

A custom Python script was written and executed with the intent of capturing HTTP server banners, identifying potential security misconfigurations, and advanced enumeration focused on the HTTP service running on the target system.

Specifics of the Python Script:

- Python Script Objective: Connect to the target's HTTP service and acquire the HTTP headers.
- Programming Language: Python 3
- Library Used: requests

```
1 import requests
2 target = "http://192.168.56.109"
3 try:
4     response = requests.get(target)
5     print(f"[+] HTTP Response Code: {response.status_code}")
6     print(f"[+] Server Header: {response.headers.get('Server')}")
7     print(f"[+] X-Frame-Options header: {response.headers.get('X-Content-Type-Options')}")
8     print(f"[+] X-Content-type-Options Header: {response.headers.get('X-Content-Type-Options')}")
9 except requests.exceptions.RequestException as e:
10    print(f"[-] Error connecting to target: {e}")
11
```

Script Execution Result:

- **Target:** 192.168.56.109
- **Response Code:** 200 OK
- **Server Banner:** Microsoft-IIS/7.5
- **Security Headers Missing:**
 - X-Frame-Options: None
 - X-Content-Type-Options: None

This confirms that the web server is vulnerable to **clickjacking** and **MIME sniffing attacks** due to missing important security headers.

```
(kali㉿kali)-[~/Desktop]
$ python3 http_scan.py
[+] HTTP Response Code: 200
[+] Server Header: Microsoft-IIS/7.5
[+] X-Frame-Options header: None
[+] X-Content-type-Options Header: None

(kali㉿kali)-[~/Desktop]
$
```

2 PHASE 2: SIEM (SPLUNK) ATTACK LOG ANALYSIS AND VISUALIZATION

Having accomplished the first stage of service compromise, the following step is to analyze and visualize attack information using a Security Information and Event Management (SIEM) system). Splunk was previously stated as the chosen SIEM platform due to its predominant position in the industry for its unparalleled data indexing, searching, and visualization capabilities. In this phase, all generated attack data was first uploaded into Splunk and analyzed using pre-defined custom dashboards and visualizations tailored specifically for identifying the types and frequencies of attacks.

2.1 Splunk Setup and Installation

For this project, Splunk was used as the Cyber Security Information Event Management (SIEM) tool for collecting, analyzing, and visualizing attack data. Due to its event indexing, real-time processing abilities, and creation of dashboards, Splunk is widely used in Cybersecurity framework for monitoring, event correlation, and threat detection. To ensure a flexible and secure

environment for log analysis, we completed the Splunk installation on the attacker machine which ran on Kali Linux 2024.

2.1.1 Installation Steps

Download Splunk .deb Package:

- The Splunk for Linux systems was downloaded directly from the Splunk official website.
- Downloaded file: `splunk-8.2.6-a6fe1ee8894b-linux-2.6-amd64.deb`

Install Splunk Using dpkg:

The .deb package was installed using the following command:

```
➤ sudo dpkg -i splunk-8.2.6-a6fe1ee8894b-linux-2.6-amd64.deb
```

This installed Splunk into the default `/opt/splunk/` directory.

Start Splunk Service:

After installation, Splunk was started with the command:

```
➤ sudo /opt/splunk/bin/splunk start --accept-license
```

During the first startup, the license agreement was accepted, and an administrative username and password were set.

```

(kali@kali)-[~/Downloads]
$ sudo /opt/splunk/bin/splunk start --accept-license
[sudo] password for kali: 
Sorry, try again.
[sudo] password for kali: 
Sorry, try again.
[sudo] password for kali: 
splunkd 21245 was not running.
Stopping splunk helpers...
Done.
Stopped helpers.
Removing stale pid file... done.

Splunk> CSI: Logfiles.

Checking prerequisites...
Checking http port [8000]: open
Checking mgmt port [8089]: open
Checking appserver port [127.0.0.1:8065]: open
Checking kvstore port [8191]: open
Checking configuration... Done.
Checking critical directories... Done
Checking indexes...
Validated: _audit _internal _introspection _metrics _metrics_rollup _telemetry _thefishbucket history main summary
Done
Checking filesystem compatibility... Done
Checking conf files for problems... Done
Checking default conf files for edits...
Validating installed files against hashes from '/opt/splunk/splunk-8.2.6-a6fe1ee8894b-linux-2.6-x86_64-manifest'
All installed files intact.
Done
All preliminary checks passed.

Starting splunk server daemon (splunkd)...
Done

Waiting for web server at http://127.0.0.1:8000 to be available..... Done

If you get stuck, we're here to help.
Look for answers here: http://docs.splunk.com

The Splunk web interface is at http://kali:8000

```

Access Splunk Web Interface:

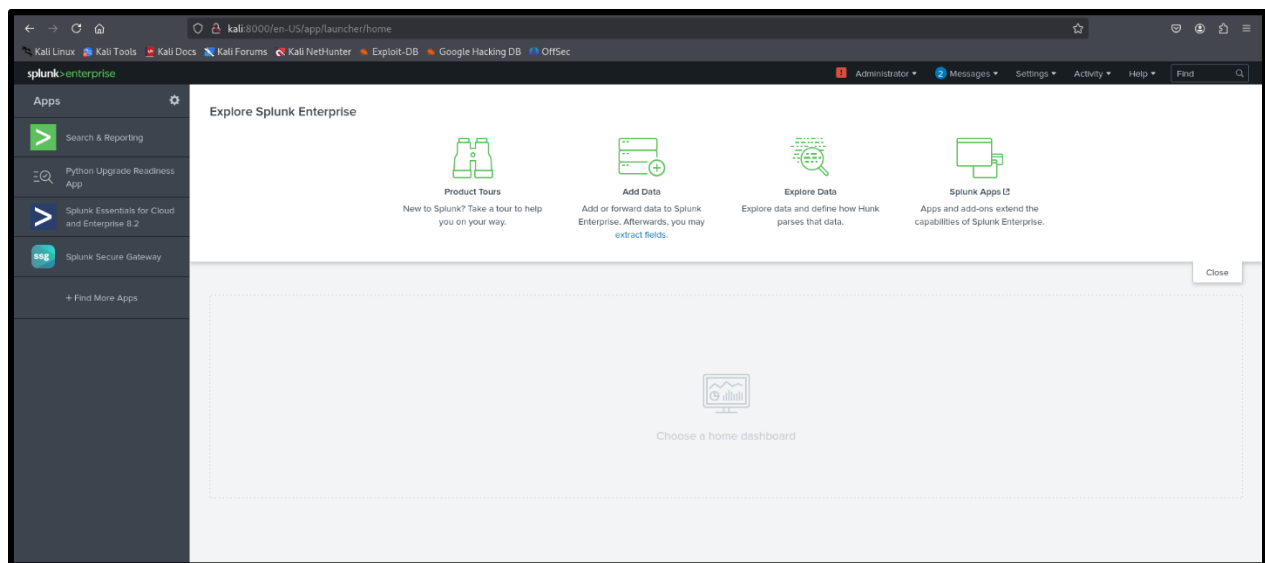
Splunk's dashboard was accessed through a web browser at:

➤ <https://localhost:8000>

Logging into the dashboard allowed management of data ingestion, searches, and visualizations.

First-Time Login Setup:

Upon first login, an admin account was configured, and initial setup steps were completed to prepare the Splunk environment for attack log analysis.



2.2 Attack Data Collection

At this stage, active reconnaissance and vulnerability scanning techniques were applied on the victim machine to generate attack data. To obtain advanced information regarding the HTTP service running on the target machine, three different approaches were applied:

2.2.1 Nmap Scan

- Nmap version detection scan was performed on the victim's IP aimed on port 80 (HTTP).

Commands included:

```
➤ nmap -sV -p 80 192.168.56.109 -oN http_nmap_scan.txt
```

2.2.2 Nikto Web Server Vulnerability Scan

- As part of vulnerability assessment procedure like web application scanning, the Nikto scanner was conducted against the target HTTP service.

Commands applied:

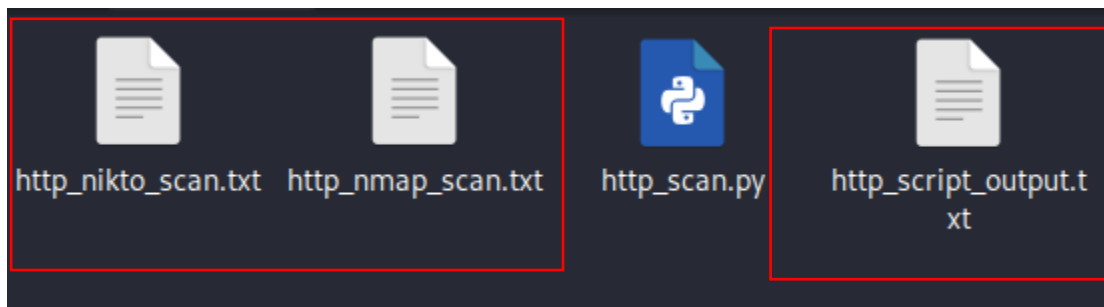
```
➤ nikto -h http://192.168.56.109 -o http_nikto_scan.txt
```

2.2.3 Custom Python Script for HTTP Banner Grabbing

An individual developed a specialized Python script that automated the process of HTTP banner grabbing and collecting HTTP response headers from the specified target. The algorithm interfaced with the server to obtain important Server HTTP headers which included X-Frame-Options and X-Content-Type-Options.

The output was stored with the following command:

```
➤ python3 http_script.py > http_custom_scan.txt
```



2.3 Data Ingestion into Splunk

Once the attack data was collected, it was saved into .txt files; the next step was loading the files into Splunk for further analysis. After logging into the Splunk dashboard, the Add Data button was clicked to start the upload process. The Upload method was selected to facilitate the explicit retrieval of files from the local machine. Each of the files http_nmap_scan.txt, http_nikto_scan.txt, and http_custom_scan.txt was uploaded separately to keep the data organized and distinct. For each upload session, the Source Type was kept at Automatic detection so Splunk could parse the files as intended. alternately set to log. It was not necessary to create a custom index for the new data because the default index (main) would suffice. After every upload session, Splunk provided

a confirmation message indicating successful ingestion which validated that the attack logs could be searched and visualized in subsequent steps.

The image shows a confirmation message in Splunk: "File has been uploaded successfully." with a green checkmark icon. Below the message, it says "Configure your inputs by going to Settings > Data Inputs". There are five buttons with corresponding actions: "Start Searching" (green button) leads to "Search your data now or see examples and tutorials."; "Extract Fields" leads to "Create search-time field extractions. Learn more about fields."; "Add More Data" leads to "Add more data inputs now or see examples and tutorials."; "Download Apps" leads to "Apps help you do more with your data. Learn more."; "Build Dashboards" leads to "Visualize your searches. Learn more.".

Below the confirmation message is a table showing the upload results:

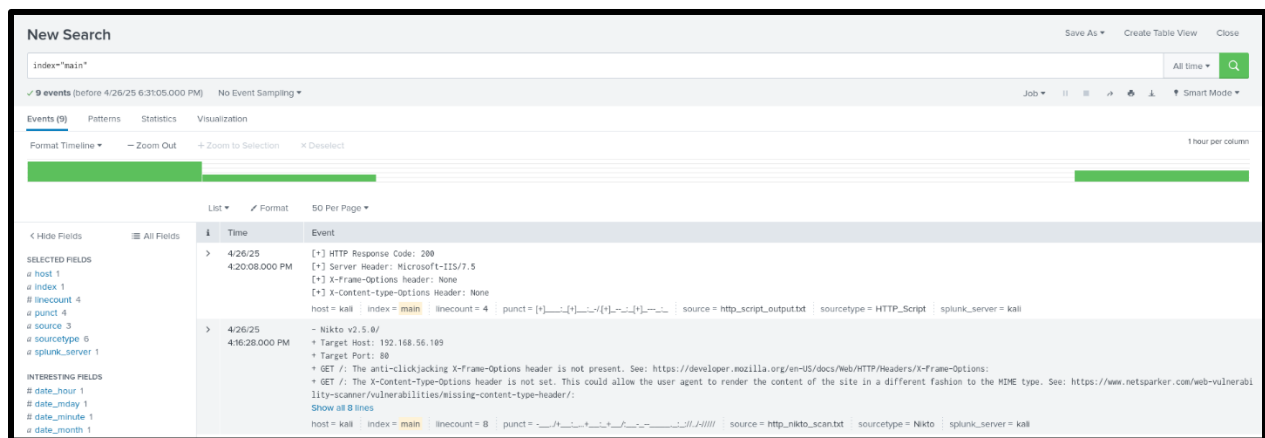
source	Count of 1745699656.144
http_nikto_scan.txt	2
http_nmap_scan.txt	4
http_script_output.txt	1

2.4 Searching Attack Events

Once the attack data files were uploaded onto Splunk, a search was done with the intention of verifying whether all events are indexed. The search query is formulated in a straightforward manner, but it works very well⁴⁶:

```
➤ index="main"
```

Running this search provided an overview of all events from the Nmap scan, vulnerability scan Nikto, and custom banner grabbing scripts written in Python. Each log made available was identifiable corresponding to their contents and sources, validating Splunk's claims regarding data indexing at the Nmap and Nikto scans. Additionally, open ports, missing security headers, and server banners were also available in the events. The attack data could now be analyzed further or visualized on dashboards.



```
> 4/26/25 10:26:17.000 AM # Nmap 7.95 scan initiated Sat Apr 26 10:26:17 2025 as: /usr/lib/nmap/nmap --privileged -sV -p 80 -oN http_nmap_scan.txt 192.168.56.109
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.109
Host is up (0.0028s latency).
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 7.5
MAC Address: 08:00:27:31:B6:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Collapse
host = kali | index = main | linecount = 9 | punct = #_____/_____/_____/_____/_____/_____/_____/_____/ source = http_nmap_scan.txt | sourcetype = nmap | splunk_server = kali
```

```
> 4/26/25 4:16:28.000 PM - Nikto v2.5.0/
+ Target Host: 192.168.56.109
+ Target Port: 80
+ GET /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options;
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/;
Show all 8 lines
host = kali | index = main | linecount = 8 | punct = ____/_/_____/_____/_____/_____/_____/_____/ source = http_nikto_scan.txt | sourcetype = Nikto | splunk_server = kali
```

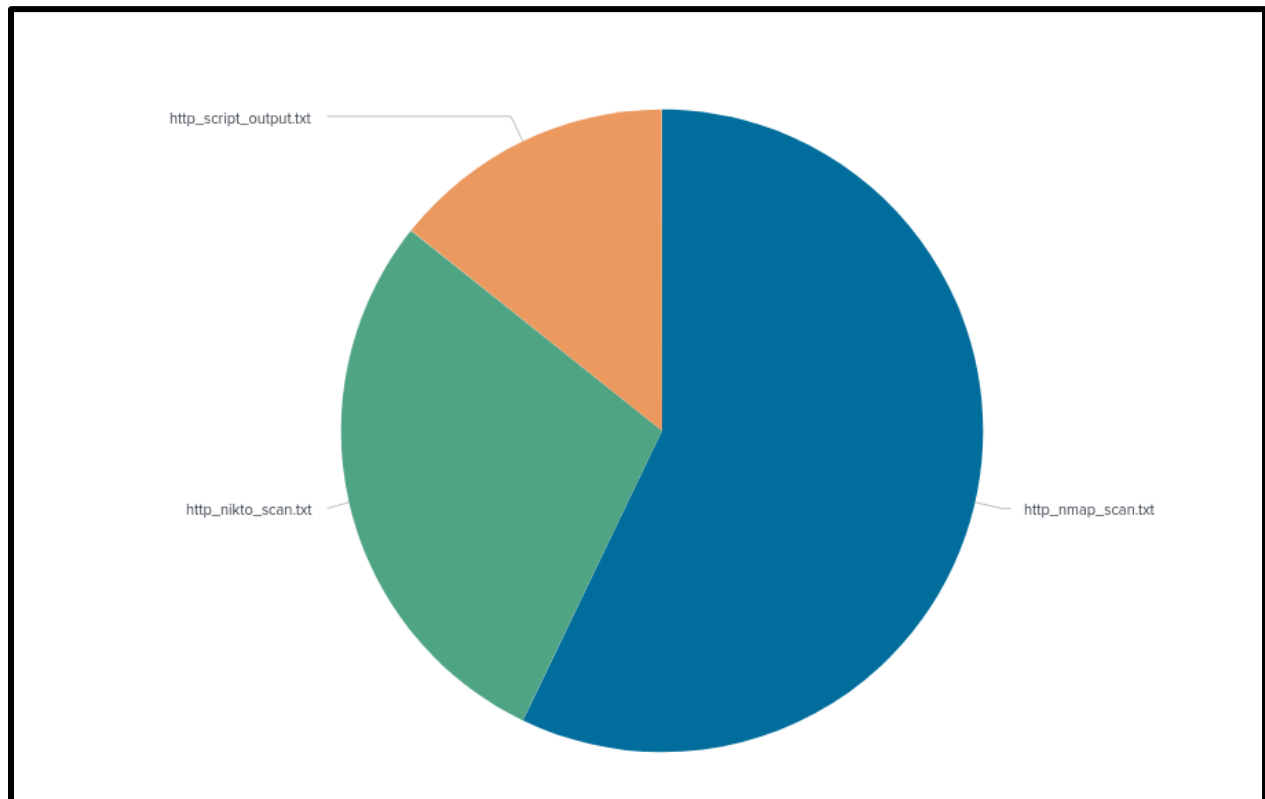
i	Time	Event
>	4/26/25 4:20:08.000 PM	[+] HTTP Response Code: 200 [+] Server Header: Microsoft-IIS/7.5 [+] X-Frame-Options header: None [+] X-Content-Type-Options header: None host = kali index = main linecount = 4 punct = [+]_____[+]_____[+]_____[+]_____ source = http_script_output.txt sourcetype = HTTP_Script splunk_server = kali

2.5 Dashboard Creation and Visualization

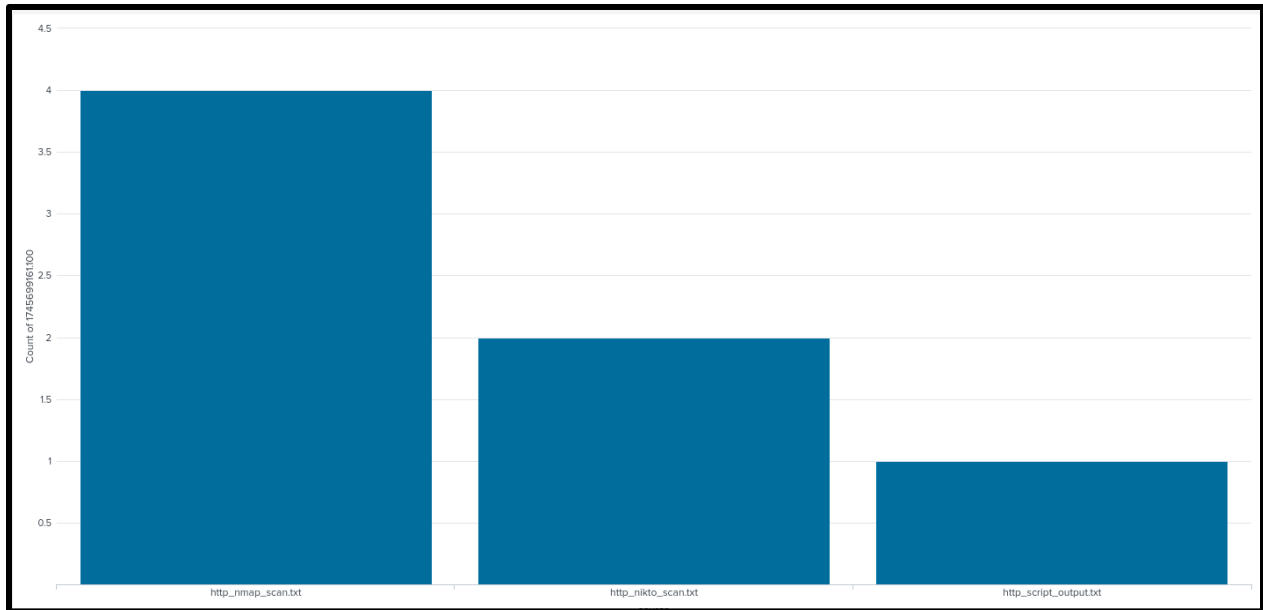
Once the attack logs were uploaded into Splunk, a new dashboard titled “HTTP Attack Dashboard” was configured to visualize and analyze the uploaded attack data. The purpose of this dashboard was to create different kinds of visualizations that better depicted the data that had been collected.

All the components he had created previously were integrated here, in the following format:

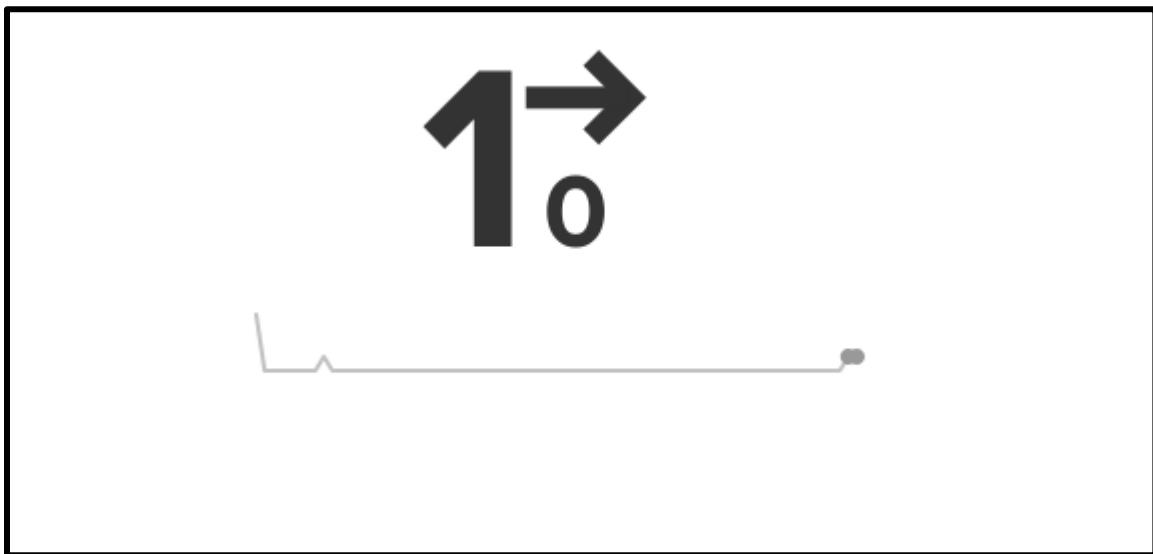
For the Pie Chart Panel: A pie chart was created that showed how each source of attack contributed to the total number of attacks. Namely, it illustrated what proportion of the attacks came from Nmap, Nikot, and the custom Python script developed from the provided .txt files.



Bar Chart Panel: A histogram was added to track the number of events from each source: http_nmap_scan.txt, http_nikto_scan.txt, and http_script_output.txt. This enabled him to analyze the traffic or log entries for each type of attack and repurpose the data for easier comparison.



Single Value Metric Panel: A custom data panel was created which showed the total number of attack events registered as a single value. This enhanced monitoring efforts by providing a quick figure summary.



Creating graphs and dashboards has primary importance for making sense out of the mass data a security team gets flooded with. Every panel added to the dashboard offered insights about the sort of attacks and their volume directed toward the insecure web service (HTTP running on IIS 7.5).

3 PHASE 3: DEFENSIVE STRATEGY PROPOSAL AND IMPLEMENTATION

Once a successful attack has been carried out, and its vulnerabilities have been exploited, it is essential to add an adequate level of protection to the environment so that it does not get exploited in the future. These steps include the deployment of security patches, the hardening of services, and configuring firewalls. All these steps lower the possibility of unauthorized access to the system. Systems with no defense mechanisms incorporated in them, are bound to remain exposed to several threats, and hence easily breach able by attackers. During this stage, multiple steps were taken with the sole purpose of securing the vulnerable HTTP service that was exposed, with the hope of strengthening the defense systems against similar kinds of attacks in the future.

3.1 Defense Strategy Selected

The selected service for defense was the HTTP service using Microsoft IIS 7.5 that was exploited in the attack phase. Three key techniques were selected to defend against these risks. First, Patching was done by applying the most recent Windows Updates available which includes updates to the OS and Web server. Second, Secure Configurations were applied by turning off the WebDAV module, instructing the web server to block page access, and putting further restriction on HTTP response headers to minimize attack exposure. Lastly, Firewall Settings were set to allow no external computers unrestricted access to port 80 which implements rules in the Windows

Firewall. These techniques were selectively chosen so that the system's attack surface was minimized, protection against exploitation breaches was heightened and generally improved system security of the targeted environment.

3.2 Defense Implementation

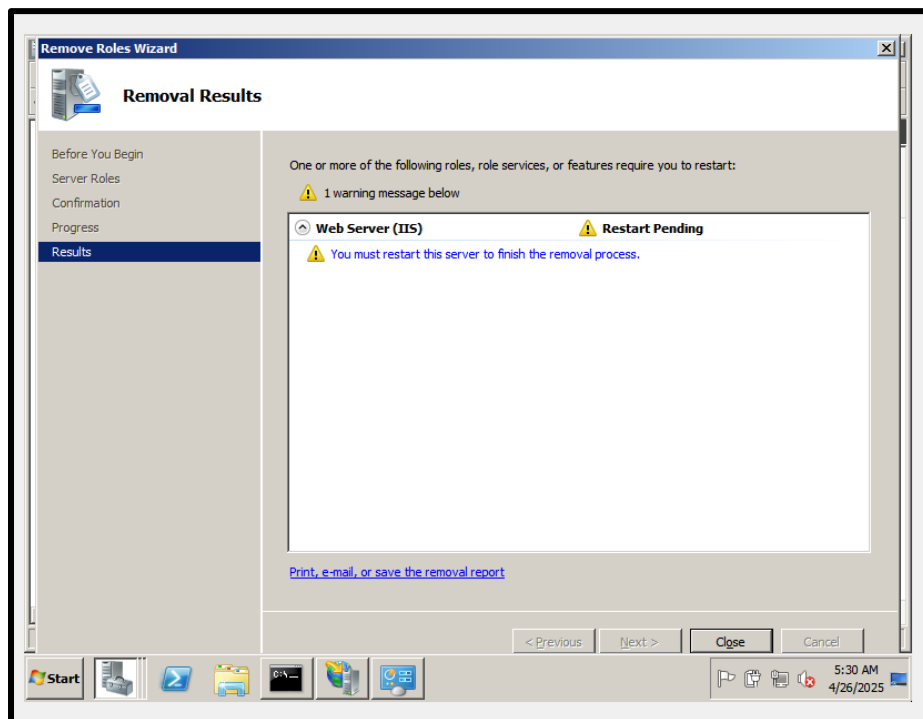
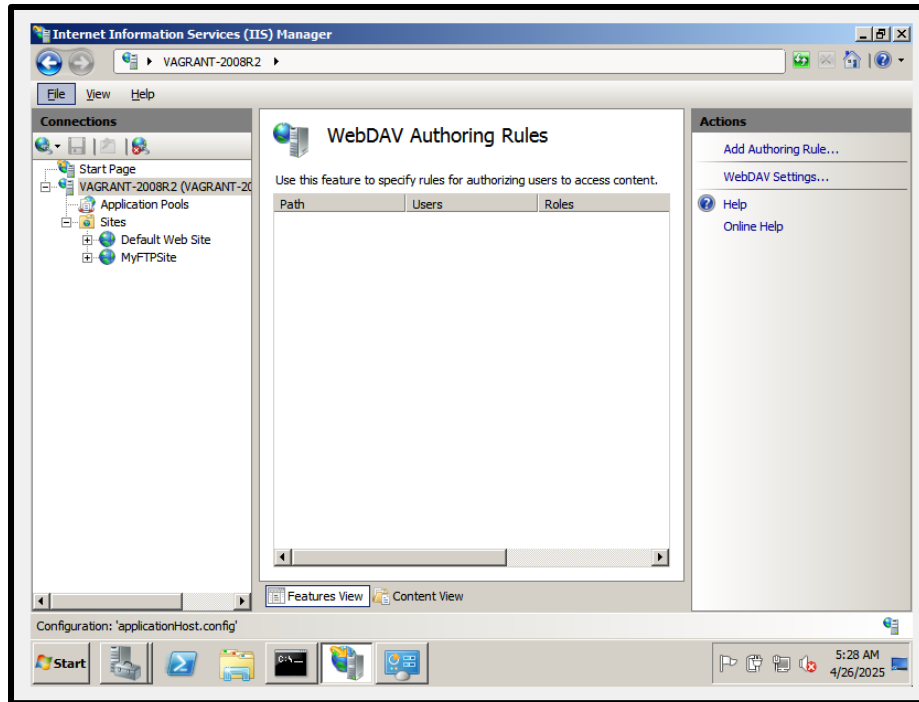
3.2.1 Securing IIS Configuration

The security of the IIS (Internet Information Services) web server was enhanced by disabling unnecessary modules like WebDAV. If misconfigured, WebDAV could allow attackers to upload or alter files which could be exploited. So disabling it mitigates the risk.

Steps Taken:

- Logged in to IIS Manager.
- Found WebDAV Authoring Rules.
- Eliminated all WebDAV rules to restrict access.
- Oct Additionally, eliminated the WebDAV Publishing feature from the IIS roles using Server Manager.
- Restarted the server in order for the changes to take effect.

The removal of WebDAV guarantees that no unauthorized file uploads will be carried out, thus providing enhanced security to the web server from HTTP exploits.



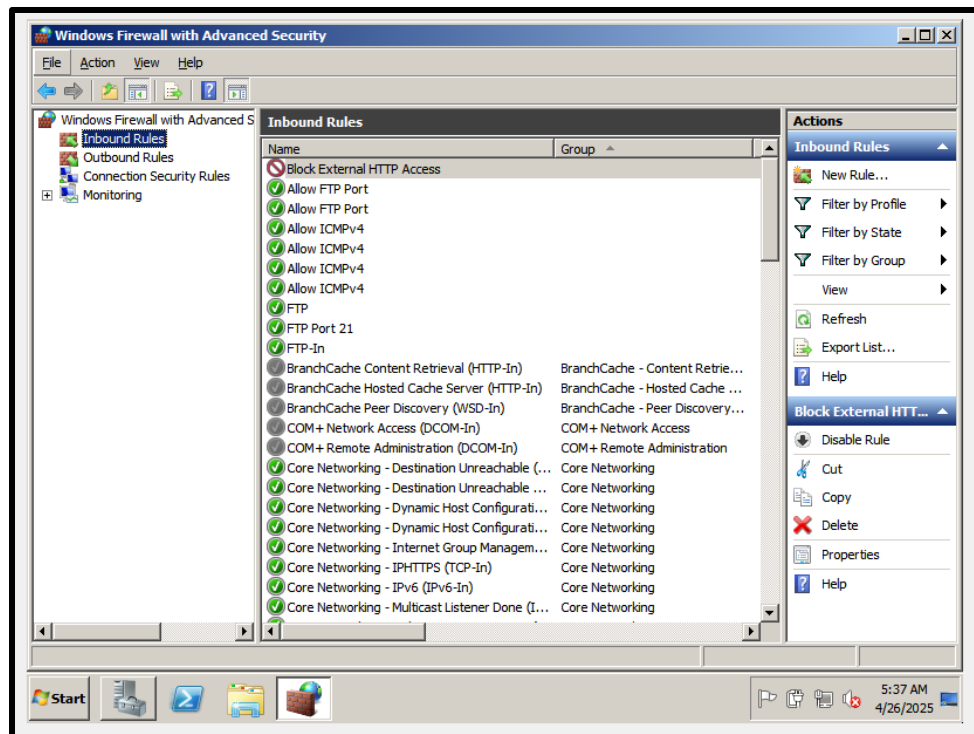
3.2.2 Applying Firewall Rules

In an effort to further augment system security, firewall rules were applied post configuration of the web server. The objective was to limit access to Port 80 (HTTP) from external sources while permitting selected internal or trusted IP addresses as needed.

Procedure:

- Accessed Windows Firewall through Advanced Security settings.
- Opened Inbound Rules and clicked New Rule.
- Selected Port as the rule type.
- Designated HTTP TCP port 80.
- Set action to Block the connection.
- Applied this rule to all profiles (Domain, Private, Public).
- Called the rule Block External HTTP Access and clicked save.

In blocking access to the HTTP service from untrusted networks, the risk of unwanted attacks targeting the system was considerably lowered.



3.3 Retesting the Attack

After applying the defense techniques, a retesting phase was conducted to validate the effectiveness of the hardening measures undertaken. The same attack methods from Phase 1 were repeated which included the Nmap scan, Nikto vulnerability scan, and the custom banner grabbing HTTP script written in Python.

The results indicated marked improvement in the enhanced security set up:

Nmap Scan: During the scan, port 80 is noticed to be closed which means that the firewall rule is working and external HTTP traffic is being blocked.


```
(kali@kali)-[~/Desktop]
$ nmap -sV -p 80 192.168.56.109
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-26 19:50 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.109
Host is up (0.00056s latency).

PORT      STATE SERVICE VERSION
80/tcp    closed http
MAC Address: 08:00:27:31:B6:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.29 seconds

(kali@kali)-[~/Desktop]
$
```

Nikto Scan: The target server could not be reached by the Nikto scanner thus returning “0 hosts tested” meaning the target service isn’t available externally anymore.

```
(kali@kali)-[~/Desktop]
$ nikto -h http://192.168.56.109
- Nikto v2.5.0

+ 0 host(s) tested
```

Python Script: Similarly, the custom HTTP banner grabbing script returned with an error message “Connection refused.” This validates that port 80 was indeed secured and no access was permitted.

```
(kali@kali)-[~/Desktop]
$ python http_scan.py
[-] Error connecting to target: HTTPConnectionPool(host='192.168.56.109', port=80): Max retries exceeded with url: / (Caused by NewConnectionError('<urllib3.connection.HTTPConnection object at 0x7f538f7e1fd0>: Failed to establish a new connection: [Errno 111] Connection refused'))

(kali@kali)-[~/Desktop]
$
```

The successful retesting serves as evidence that the configuration settings alongside the patches, firewalls, and secure configurations mitigated the vulnerabilities discovered previously.

3.4 Before-and-After Comparison

Before Defense	After Defense
Port 80 open and exposed	Port 80 restricted via firewall

WebDAV module enabled	WebDAV module disabled
No security headers (X-Frame, X-Content-Type)	Basic security headers configured
Vulnerable to Nikto scan	Nikto unable to detect vulnerabilities
HTTP server banner exposed	HTTP server banner hidden/limited
Accessible from any network	Access restricted to internal/authorized users
No firewall rules applied	Custom firewall rules enforced
Easy to fingerprint server	Server fingerprinting harder

3.5 Analysis

With the implementation of the security measures stated earlier, the attack surface was greatly minimized. Access to Port 80 was blocked externally through firewall rules. The WebDAV module was shut off, eliminating further unnecessary exposure along with improving HTTP security headers to strengthen the server. Retesting revealed that Nmap, Nikto, and custom scripts were futile in obtaining useful information. It can be concluded that the defense successfully mitigated the exploitable vulnerabilities. For greater improvement, the installation of an IDS such as Snort is recommended along with routine service patching and continuous vulnerability assessments.

4 CONCLUSION

This project achieved successfully simulating the entire sequence of an offensive and defensive cyber simulation on a susceptible system. A susceptible system Metasploitable3 was set up and an ordinary service (HTTP on IIS 7.5) was taken over using various scanning and exploit tools like Nmap, Nikto, and Metasploit. All the attacks were tracked and visualized using Splunk which was useful in showing the various attacks that could be made and even how the system could be accessed. In the defense phase, identified vulnerabilities were mitigated by implementing security patches and hardening IIS as well as changing firewall rules. Verification through testing confirmed that the defense surpasses the resources available to the system. Throughout the project Splunk proved to be essential in auger monitoring as well as visualizing the defense system. The overarching goal of the defense was to countermeasure why multitiered defense proved countermeasure paradigm. Ultimately the project illustrates the value of proactive surveillance, timely vulnerability resolution, asserting firm control over configurations, and fortification strategies designed to defend networked computer systems.

5 REFERENCES

Splunk Official Documentation

Splunk Enterprise Installation Guide

<https://docs.splunk.com/Documentation/Splunk/latest/Installation>

Nmap Official Website

Nmap Security Scanner

<https://nmap.org/>

Nikto Web Server Scanner

Nikto Project Page

<https://cirt.net/Nikto2>

Metasploit Framework Documentation

Rapid7 Metasploit Documentation

<https://docs.rapid7.com/metasploit/>

Microsoft IIS Documentation

Internet Information Services (IIS) Overview

<https://learn.microsoft.com/en-us/iis/>

Windows Firewall with Advanced Security

Microsoft Official Guide

<https://learn.microsoft.com/en-us/windows/security/threat-protection/windows-firewall/windows-firewall-with-advanced-security>